BÀI THỰC HÀNH 07

DNS Security Extensions (DNSSEC)

Deploying & Validating DNSSEC — Defeating DNS Forgery

Thời lượng	120 phút
Mức độ	Trung bình–Khó
Môi trường	1 VM Kali Linux · ip netns + bridge (4 host ảo)
Công cụ	BIND9 (named), unbound, dig, tcpdump

⚠ Bài thực hành chỉ được thực hiện trong môi trường phòng lab cô lập (máy ảo + network namespace trên chính máy của bạn). Mọi kỹ thuật ở đây thuộc nhóm tấn công mạng; việc áp dụng lên hệ thống/mạng không thuộc quyền sở hữu hoặc không được cho phép bằng văn bản là VI PHẠM PHÁP LUẬT (Luật An ninh mạng 2018 — Luật số 24/2018/QH14, và Bộ luật Hình sự). Mục tiêu học tập là hiểu cơ chế để phòng thủ (defensive security).

Mục tiêu bài học

- Hiểu điểm yếu của DNS truyền thống: **không có toàn vẹn/xác thực** ⇒bị giả mạo (spoofing/cache poisoning).
- Triển khai một **vùng DNS được ký DNSSEC** (BIND9) và một **resolver kiểm tra chữ ký** (unbound).
- Quan sát cờ **AD (Authenticated Data)** khi xác thực thành công.
- Chứng minh dữ liệu **giả mạo (không chữ ký) bị từ chối (SERVFAIL)** — trong khi không có DNSSEC thì bị lừa.

Kiến thức nền tối thiểu

- DNSSEC thêm các bản ghi RRSIG (chữ ký), DNSKEY (khóa công khai), DS (liên kết tin cậy) để resolver kiểm tra tính toàn vẹn & nguồn gốc.
- Nếu dữ liệu bị sửa hoặc không có chữ ký hợp lệ, resolver có DNSSEC trả về SERVFAIL thay vì chấp nhận.
- Trong lab (không có Internet), ta tạo một 'đảo tin cậy' (island of trust) cho vùng `lab.test`.

1. Chuẩn bị môi trường

▸Cài gói (một lần)

```
apt update && apt install -y bind9 bind9-dnsutils unbound
```

▸setup_dns.sh — chạy: sudo bash setup_dns.sh

```
#!/bin/bash
# setup_dns.sh - LAN 10.0.0.0/24: dns-auth(.2), dns-res(.3), client(.4), rogue(.66)
set -e
ip link add br0 type bridge; ip link set br0 up
add_host() { ns=$1; ipaddr=$2
  ip netns add $ns
  ip link add ${ns}0 type veth peer name ${ns}-br
  ip link set ${ns}-br master br0; ip link set ${ns}-br up
  ip link set ${ns}0 netns $ns
  ip netns exec $ns ip addr add ${ipaddr}/24 dev ${ns}0
  ip netns exec $ns ip link set ${ns}0 up; ip netns exec $ns ip link set lo up
}
add_host dns-auth 10.0.0.2      # may chu uy quyen (BIND9, co ky DNSSEC)
add_host dns-res  10.0.0.3      # resolver kiem tra DNSSEC (unbound)
add_host client   10.0.0.4      # may khach
```

```
add_host rogue    10.0.0.66     # may chu DNS gia mao (khong ky)
echo "[+] LAN DNS san sang"
```

Gợi ý: mở mỗi dịch vụ trong một terminal riêng bằng `sudo ip netns exec <ns> bash` để dễ quản lý các tiến trình nền.

2. Thiết lập máy chủ uỷ quyền có ký DNSSEC

Tạo các tệp cấu hình và dữ liệu vùng:

▸ *Tạo /tmp/named-auth.conf*

```
// /tmp/named-auth.conf  (may chu uy quyen - CO ky DNSSEC)
options {
    directory "/var/cache/bind";
    listen-on port 53 { 10.0.0.2; };
    listen-on-v6 { none; };
    recursion no;
    dnssec-validation no;
};
zone "lab.test" {
    type primary;
    file "db.lab.test";
    dnssec-policy default;       // tu dong sinh khoa & ky zone
    inline-signing yes;
};
```

▸ *Tạo tệp vùng (đặt tại /var/cache/bind/db.lab.test)*

```
; /var/cache/bind/db.lab.test
$TTL 3600
@   IN SOA ns1.lab.test. admin.lab.test. ( 2026101901 3600 600 604800 3600 )
@   IN NS  ns1.lab.test.
ns1 IN A   10.0.0.2
www IN A   10.0.0.80
```

▸ *Chạy máy chủ uỷ quyền trong ns dns-auth*

```
cp db.lab.test /var/cache/bind/db.lab.test
chown bind:bind /var/cache/bind/db.lab.test
ip netns exec dns-auth named -c /tmp/named-auth.conf -g &
sleep 3    # cho BIND sinh khoa va ky zone
```

Ghi chú: nếu AppArmor chặn named (xem lỗi trong log), chạy `sudo aa-complain /usr/sbin/named` rồi thử lại.

3. Tạo trust anchor cho resolver

```
# Lay DNSKEY cua lab.test, giu lai khoa ky khoa (KSK, co flag 257)
ip netns exec client dig @10.0.0.2 lab.test DNSKEY > /tmp/lab.dnskey
grep -E "IN[[:space:]]+DNSKEY[[:space:]]+257" /tmp/lab.dnskey > /tmp/trust-anchor.key
echo "=== Trust anchor ==="; cat /tmp/trust-anchor.key
```

✓**Kết quả mong đợi:** Tệp /tmp/trust-anchor.key chứa một dòng DNSKEY 257 (Key Signing Key) của vùng lab.test — đây là "neo tin cậy" để resolver xác thực.

4. Cấu hình & chạy resolver kiểm tra DNSSEC

▸ *Tạo /tmp/unbound.conf*

```
# /tmp/unbound.conf  (resolver KIEM TRA DNSSEC)
server:
    verbosity: 1
    interface: 10.0.0.3
    port: 53
    username: ""
    chroot: ""
    use-syslog: no
    pidfile: "/tmp/unbound.pid"
    directory: "/tmp"
    do-ip6: no
    access-control: 10.0.0.0/24 allow
    module-config: "validator iterator"
    harden-dnssec-stripped: yes
    val-permissive-mode: no
    trust-anchor-file: "/tmp/trust-anchor.key"
    domain-insecure: "."           # khong co Internet -> chi lab.test duoc xac thuc
stub-zone:
    name: "lab.test"
    stub-addr: 10.0.0.2
```

▸ *Chạy unbound trong ns dns-res*

```
ip netns exec dns-res unbound -c /tmp/unbound.conf -d &
```

5. Các bước thực hành

Bước 5.1 — Truy vấn hợp lệ: xác thực thành công (cờ AD)

▸ *Terminal client*

```
ip netns exec client dig @10.0.0.3 www.lab.test +dnssec
```

✓**Kết quả mong đợi:** Kết quả NOERROR, trả về A = 10.0.0.80, phần "flags:" có **ad** (Authenticated Data) và xuất hiện bản ghi RRSIG ⇒DNSSEC xác thực thành công.

Bước 5.2 — Dựng máy chủ DNS giả mạo (không chữ ký)

▸ *Tạo /tmp/named-rogue.conf*

```
// /tmp/named-rogue.conf  (may chu GIA MAO - KHONG ky)
options {
    directory "/var/cache/bind";
    listen-on port 53 { 10.0.0.66; };
    listen-on-v6 { none; };
    recursion no;
    dnssec-validation no;
};
zone "lab.test" {
    type primary;
    file "db.lab.rogue";          // www tro ve 6.6.6.6, khong co chu ky
};
```

▸ *Tạo /var/cache/bind/db.lab.rogue*

```
; /var/cache/bind/db.lab.rogue
$TTL 3600
@   IN SOA ns1.lab.test. admin.lab.test. ( 2026101902 3600 600 604800 3600 )
@   IN NS  ns1.lab.test.
```

```
ns1 IN A   10.0.0.2
www IN A   6.6.6.6
```

▸ *Chạy máy chủ giả mạo (ns rogue, .66)*

```
cp db.lab.rogue /var/cache/bind/db.lab.rogue
chown bind:bind /var/cache/bind/db.lab.rogue
ip netns exec rogue named -c /tmp/named-rogue.conf -g &
```

Bước 5.3 — Resolver có DNSSEC từ chối dữ liệu giả mạo

```
# Chuyen resolver sang hoi may chu GIA MAO roi khoi dong lai unbound:
sed -i 's/stub-addr: 10.0.0.2/stub-addr: 10.0.0.66/' /tmp/unbound.conf
pkill -f "unbound -c /tmp/unbound.conf"
ip netns exec dns-res unbound -c /tmp/unbound.conf -d &
sleep 2
# Truy van qua resolver co DNSSEC:
ip netns exec client dig @10.0.0.3 www.lab.test +dnssec
```

✓**Kết quả mong đợi:** Resolver trả về **SERVFAIL** — vì dữ liệu từ máy chủ giả không có chữ ký hợp lệ, DNSSEC từ chối. Người dùng KHÔNG bị dẫn tới 6.6.6.6.

Bước 5.4 — So sánh: nếu không kiểm tra DNSSEC thì bị lừa

```
# (a) Hoi thang may gia mao (khong kiem tra) -> nhan IP gia:
ip netns exec client dig @10.0.0.66 www.lab.test +short          # => 6.6.6.6
# (b) Tat kiem tra chu ky bang co +cd (Checking Disabled):
ip netns exec client dig @10.0.0.3 www.lab.test +cd +short       # => 6.6.6.6
```

✓**Kết quả mong đợi:** Khi bỏ qua kiểm tra chữ ký, client chấp nhận bản ghi giả 6.6.6.6. Đối chiếu với Bước 5.3 cho thấy rõ giá trị bảo vệ của DNSSEC: phát hiện & chặn dữ liệu bị giả mạo/sửa đổi.

6. Dọn dẹp

```
pkill named 2>/dev/null; pkill unbound 2>/dev/null
for ns in dns-auth dns-res client rogue; do ip netns del $ns 2>/dev/null; done
ip link del br0 2>/dev/null
```

Phòng chống (Mitigation)

- Ký DNSSEC cho vùng (zone signing) và công bố bản ghi DS tại vùng cha để tạo chuỗi tin cậy.
- Bật kiểm tra DNSSEC (validation) tại resolver; giám sát tỉ lệ SERVFAIL do xác thực.
- Kết hợp DNS over TLS/HTTPS (DoT/DoH) để bảo mật kênh truyền giữa client và resolver.
- Dùng NSEC3 chống liệt kê vùng; quản lý vòng đời khóa (key rollover) theo RFC 6781.

Câu hỏi ôn tập

1. Nêu chức năng của từng bản ghi: DNSKEY, RRSIG, DS. Chuỗi tin cậy (chain of trust) hình thành thế nào?
2. Cờ AD trong phản hồi dig nghĩa là gì? Khác với cờ AA ra sao?
3. Ở Bước 5.3, vì sao resolver trả về SERVFAIL thay vì trả bản ghi giả? Điều gì đã bị thiếu/không hợp lệ?
4. DNSSEC bảo vệ **toàn vẹn & xác thực nguồn gốc** nhưng KHÔNG cung cấp **tính bí mật**. Giải thích và nêu giải pháp bổ sung.

5. Phân biệt hai mối đe dọa: DNS cache poisoning (Kaminsky) và DNS spoofing trên đường truyền. DNSSEC chống được cái nào?

Tài liệu tham khảo

- RFC 4033, 4034, 4035 — DNS Security Introduction and Requirements / Resource Records / Protocol.
- RFC 5155 — DNSSEC Hashed Authenticated Denial of Existence (NSEC3).
- D. Kaminsky (2008) — DNS cache poisoning; RFC 6781 — DNSSEC Operational Practices.